

A photograph of a modern university building with large glass windows and a white facade, situated behind a field of tall grass and yellow wildflowers under a blue sky with scattered clouds. A semi-transparent grey box is overlaid on the left side of the image, containing text.

5CM512

Communication and Security Protocols

Week 8:
Countermeasures against
Insider attacks

COUNTERMEASURES AGAINST INSIDER ATTACKS



- Countermeasures:

Enforce least privilege, only allowing access to the resources employees need to do their job

Set logs to see what users access and what commands they are entering

Protect sensitive resources with strong authentication

Upon termination, delete employee's computer and network access

Upon termination, make a mirror image of employee's hard drive before reissuing it (used as evidence if your company information turns up at a competitor)

Intrusion Techniques

-

One-way functioning

- The system stores only the value of a function based on the user's password

Access control

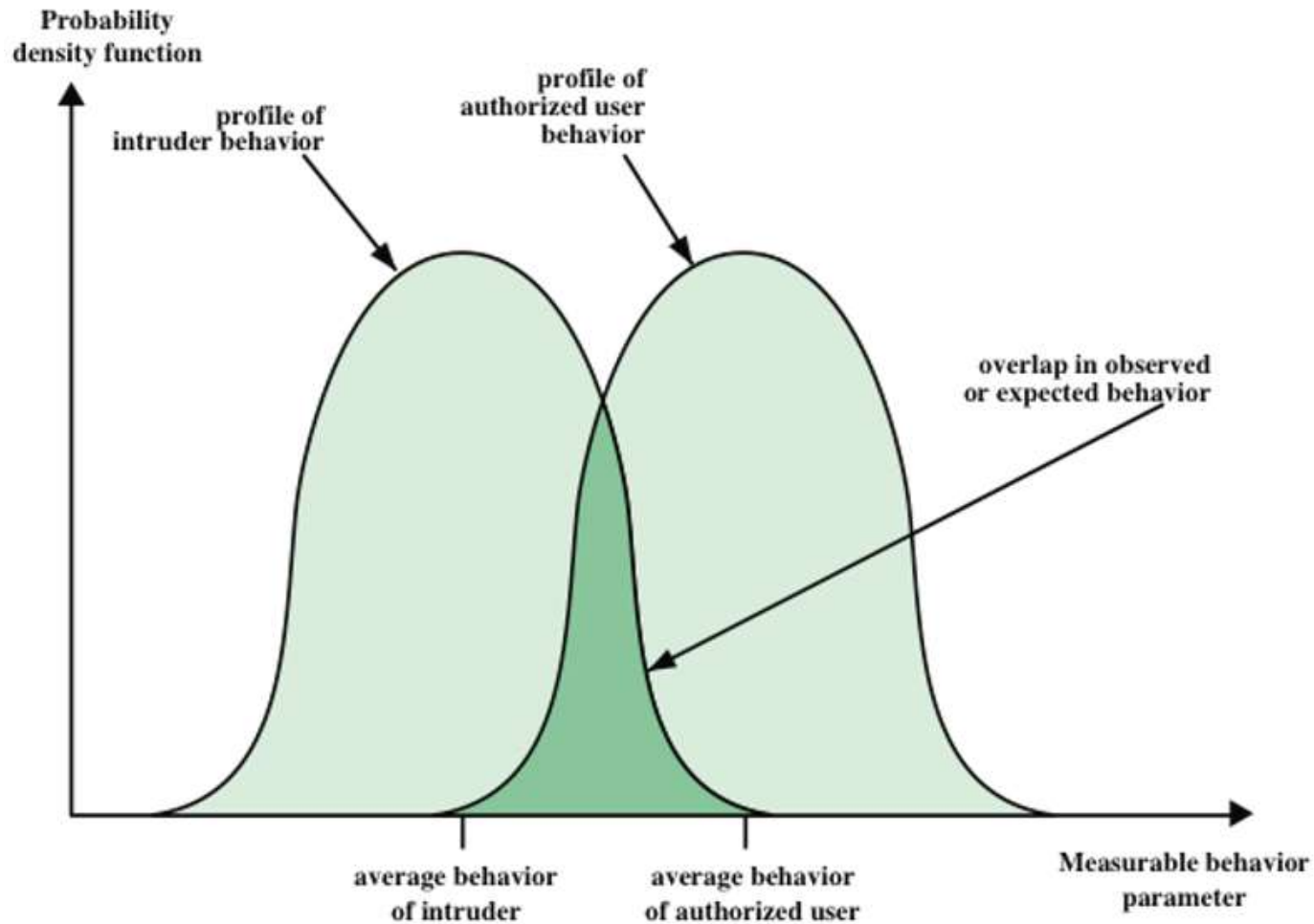
- Access to the password file is limited to one or a very few accounts

Intrusion Detection

- A system's second line of defense
- Based on the assumption :
 - The behavior of the intruder differs from that of a legitimate user in ways that can be quantified
- Considerations:
 - Detect and Eject quickly before any damage is done or any data are compromised
 - Be deterrent, so acting to prevent intrusions
 - Collect information about intrusion techniques
 - can be used to strengthen the intrusion prevention facility



Profiles of Behaviour of Intruders and Authorized Users



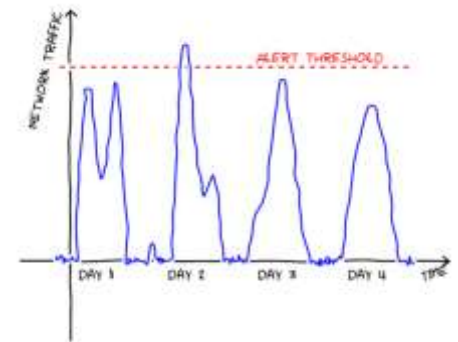
Base-Rate Fallacy

- AIM :
 - Detect a substantial percentage of intrusions
 - while keeping the false alarm rate at an acceptable level
 - If only a modest percentage of actual intrusions are detected
 - Too many **MISS**
 - the system provides a false sense of security
 - If the system frequently triggers an alert when there is no intrusion
 - Too many **FALSE ALARMS**
 - Either system managers will begin to ignore the alarms
 - or much time will be wasted analyzing the false alarms
- It is very difficult to meet the standard of high rate of detections with a low rate of false alarms

		IDS RESPONSE	
		Intrusion	Normal
REAL TRAFFIC	Intrusion	HIT	MISS
	Normal	FALSE ALARM	CORRECT DECISION

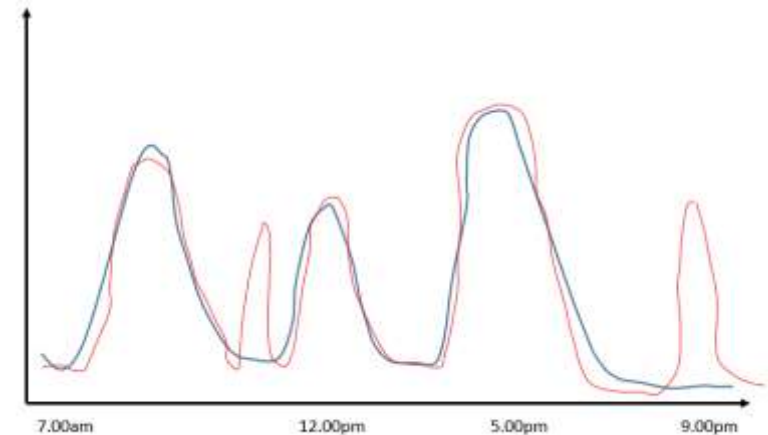
Approaches to Intrusion Detection

- Statistical anomaly detection
 - Collection of data relating to the behavior of legitimate users over a period of time
 - Statistical tests are applied to observed behavior to determine whether that behavior is not legitimate user behavior
- Threshold detection
 - This approach involves defining thresholds, independent of user, for the frequency of occurrence of various events



Approaches to Intrusion Detection

- Statistical anomaly detection
 - Profile based
 - A profile of the activity of each user is developed and used to detect changes in the behavior of individual accounts
- Rule-based detection
 - Define a set of rules or attack patterns
 - can be used to decide that a given behavior is that of an intruder
 - Often referred to as *signature detection*



Misuse Signature Intruder Detection



Example: `If (src_ip == dst_ip && src_port == dst_port)`
then "land attack"

Audit Records

- Fundamental tool for intrusion detection

Native audit records

Virtually all multiuser operating systems include accounting software that collects information on user activity

The advantage of using this information is that no additional collection software is needed

The disadvantage is that the native audit records may not contain the needed information or may not contain it in a convenient form

Detection-specific audit records

A collection facility can be implemented that generates audit records containing only that information required by the intrusion detection system

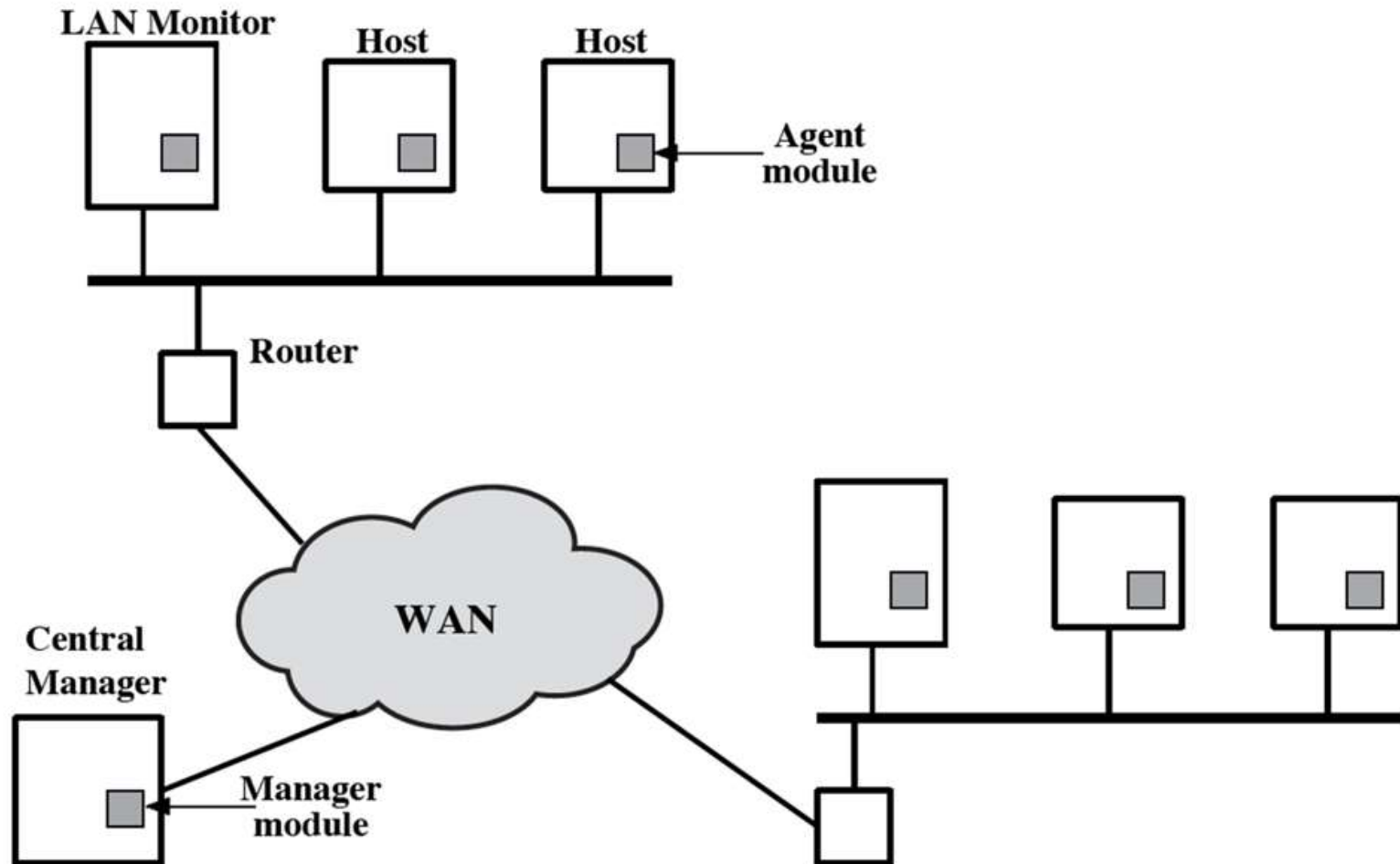
One advantage of such an approach is that it could be made vendor independent and ported to a variety of systems

The disadvantage is the extra overhead involved in having two accounting packages running on a machine

Distributed Intrusion Detection

- Traditional systems focused on single-system stand-alone facilities
- The typical organization, however, needs to defend a distributed collection of hosts supported by a LAN or internetwork
- A more effective defense can be achieved by coordination and cooperation among intrusion detection systems across the network

Architecture for Distributed Intrusion Detection



Honeypots

- Decoy systems that are designed to lure a potential attacker away from critical systems

Has no
production
value

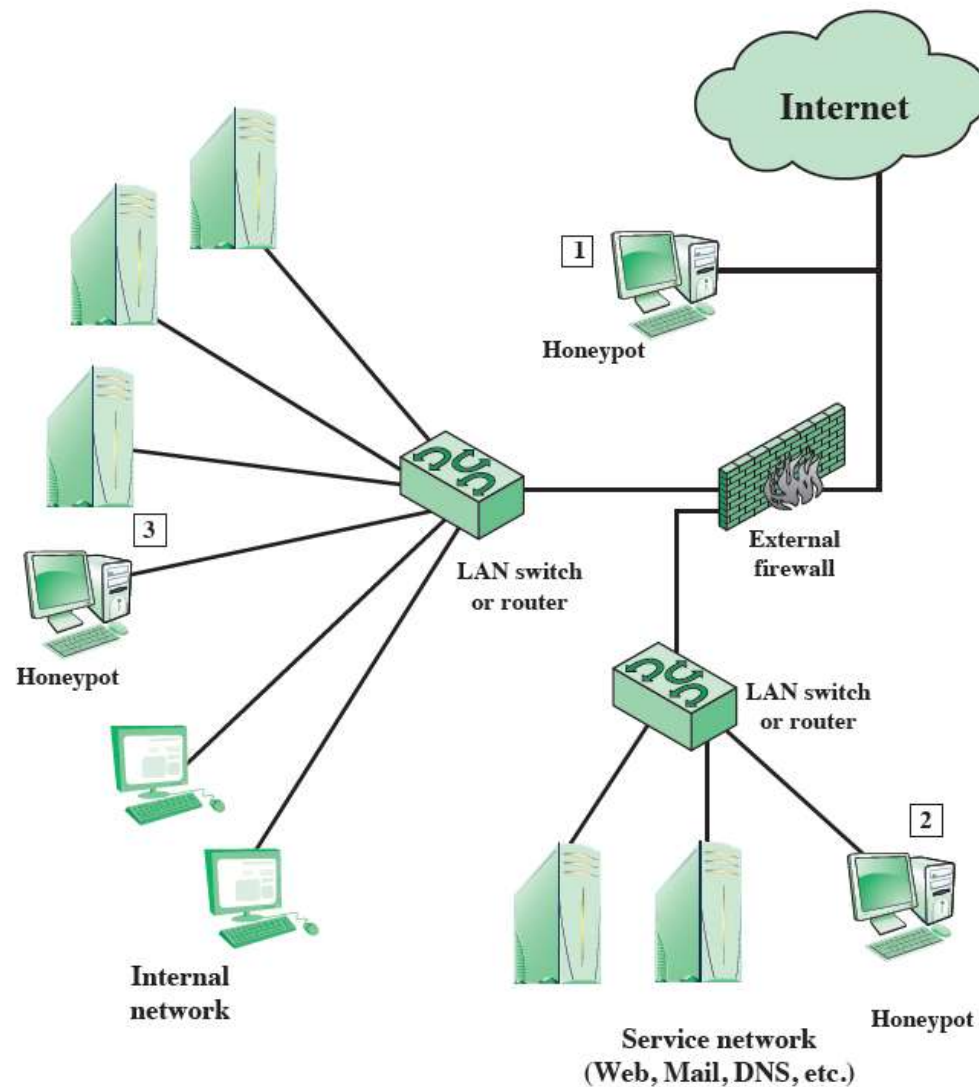
- These systems are filled with fabricated information designed to appear valuable but that a legitimate user of the system wouldn't access
- Thus, any attempt to communicate with the system is most likely a probe, scan, or attack

Designed to:

- Divert an attacker from accessing critical systems
- Collect information about the attacker's activity
- Encourage the attacker to stay on the system long enough for administrators to respond

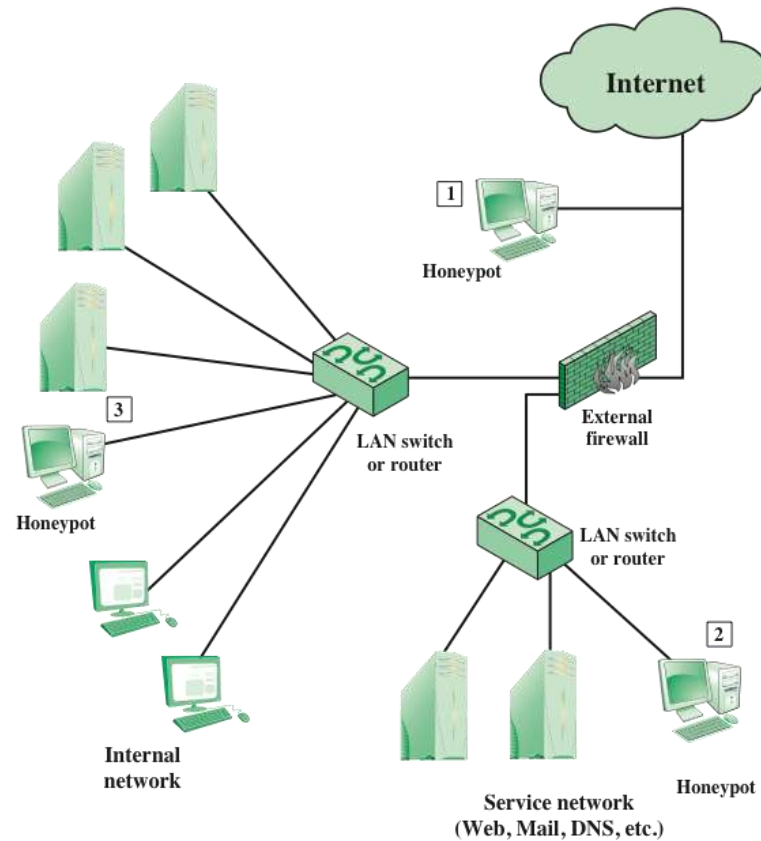
- Because any attack against the honeypot is made to seem successful, administrators have time to mobilize and log and track the attacker without ever exposing productive systems
- Recent research has focused on building entire honeypot networks that emulate an enterprise, possible with actual or simulated traffic and data

Example of Honeypot Deployment



Class exercise

- Discuss pros and cons of these three locations.



Any QUESTIONS?

